



FILE PATH TRAVERSAL, VALIDATION OF START OF PATH

ROAD TO HALL OF FAME



BRYHAN EDUARDO GUZMAN MARTINEZ

178508

SEGURIDAD INFORMÁTICA

Índice

1. Marco Teórico: Definición de Path Traversal (Directory Traversal).....	2
2. Explicación técnica de la vulnerabilidad	2
3. Explicación del payload	2
4. Evidencias y Capturas de Pantalla	3
5. Mitigación recomendada	8

1. Marco Teórico: Definición de Path Traversal (Directory Traversal)

El *Path Traversal* o salto de directorio es una vulnerabilidad de seguridad web que permite a un atacante leer archivos arbitrarios en el servidor en el que se ejecuta la aplicación. Esto incluye el acceso a código fuente de la aplicación, archivos de configuración, credenciales de bases de datos y archivos sensibles del sistema operativo (como el archivo `/etc/passwd` en sistemas Unix/Linux o `win.ini` en Windows).

2. Explicación técnica de la vulnerabilidad

La aplicación web contiene una vulnerabilidad de *path traversal* en la funcionalidad que carga y muestra las imágenes de los productos. La vulnerabilidad radica en que la aplicación transmite la ruta completa del archivo a través del parámetro `filename` en la solicitud HTTP, y como mecanismo de defensa, únicamente valida que la ruta suministrada comience con la carpeta esperada (`/var/www/images/`). Al no filtrar ni sanitizar posteriormente las secuencias de escalado de directorios (`../`), permite a un atacante acceder a archivos arbitrarios en el servidor siempre y cuando la solicitud inicie con el texto validado.

3. Explicación del payload

El payload utilizado fue: `/var/www/images/../../../../etc/passwd`.

- **`/var/www/images/`:** Se coloca al inicio del payload para cumplir con la validación de la aplicación de que la ruta debe empezar con el directorio esperado.
- **`../../../../`:** Son secuencias de salto de directorio que le indican al servidor que retroceda tres niveles desde la carpeta `/var/www/images/` hasta llegar al directorio raíz del sistema operativo (`/`).
- **`etc/passwd`:** Es el archivo confidencial objetivo que lista a los usuarios del sistema, el cual es expuesto en el cuerpo de la respuesta HTTP del servidor.

4. Evidencias y Capturas de Pantalla

Lab: File path traversal, validation of start of path

PRACTITIONER
LAB Not solved



This lab contains a path traversal vulnerability in the display of product images.

The application transmits the full file path via a request parameter, and validates that the supplied path starts with the expected folder.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Solution

1. Use Burp Suite to intercept and modify a request that fetches a product image.
2. Modify the `filename` parameter, giving it the value:
`/var/www/images/../../../../etc/passwd`
3. Observe that the response contains the contents of the `/etc/passwd` file.

Imagen 1. Tenemos el laboratorio 5 Lab: File path traversal, validation of start of path primero hacemos click en “ACCESS THE LAB”

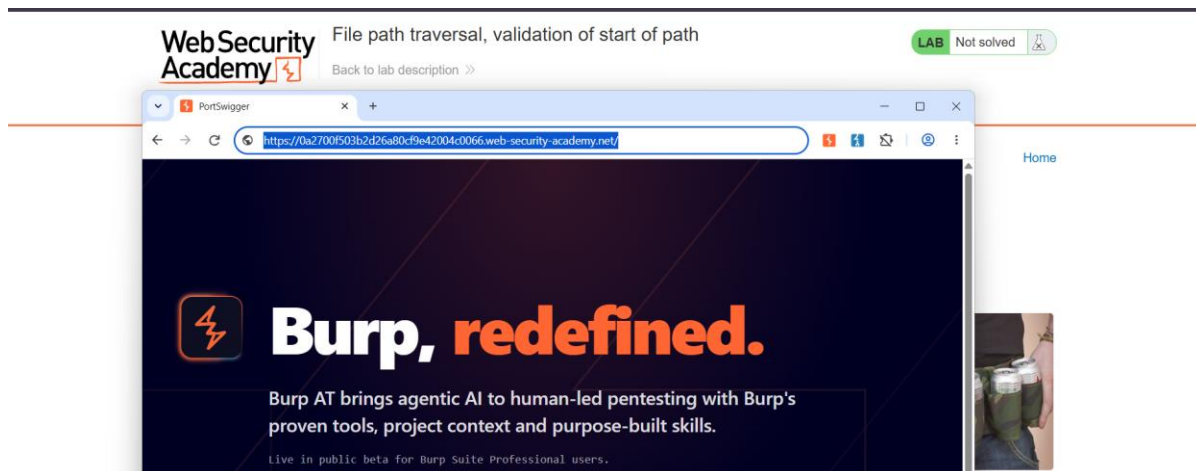


Imagen 2. Nos abre una página que nos arroja un URL el cual tenemos que copiar

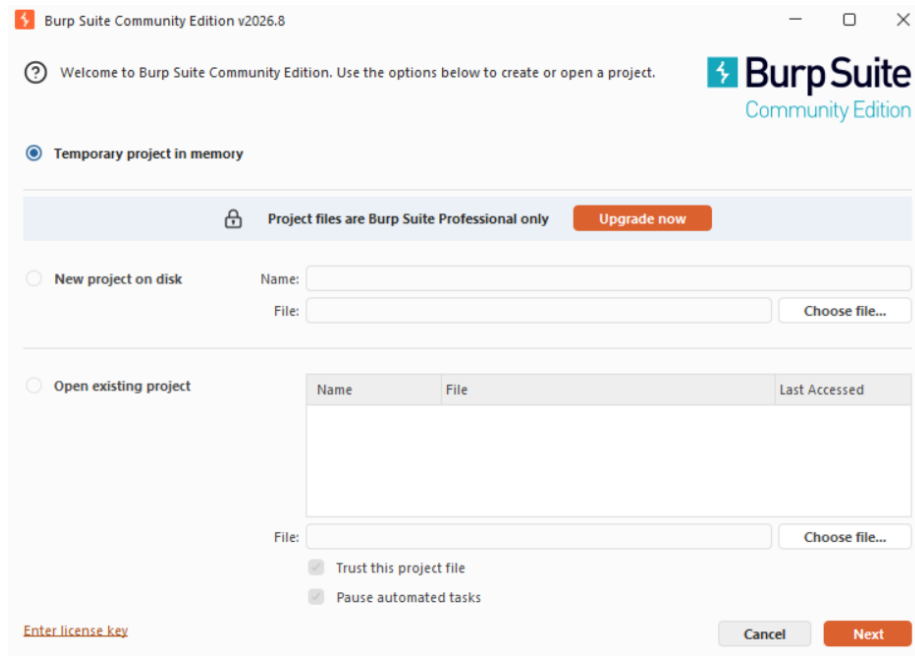


Imagen 3. Abrimos BurpSuit previamente descargado, seleccionamos “Temporary Project in memory”, después demos click en “Next”

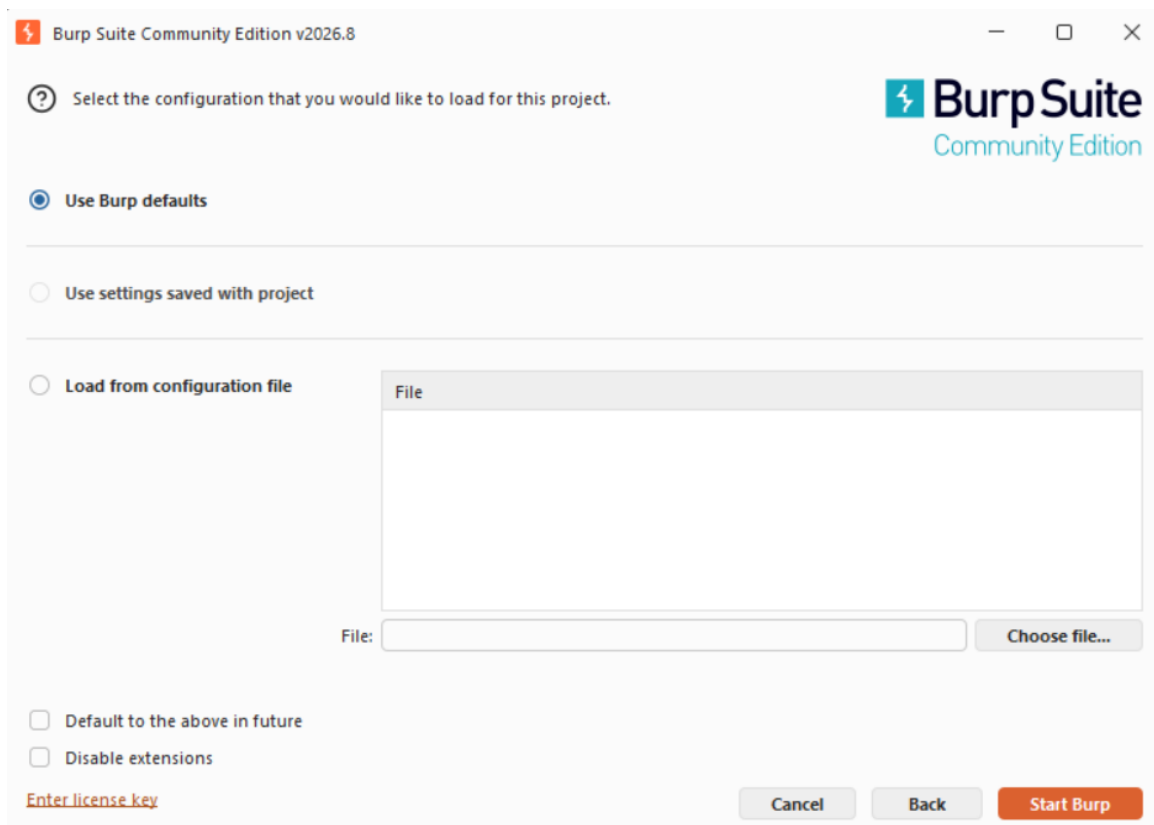


Imagen 4. Seleccionamos “Use Burp defaults” y damos click en “Start Burp”.

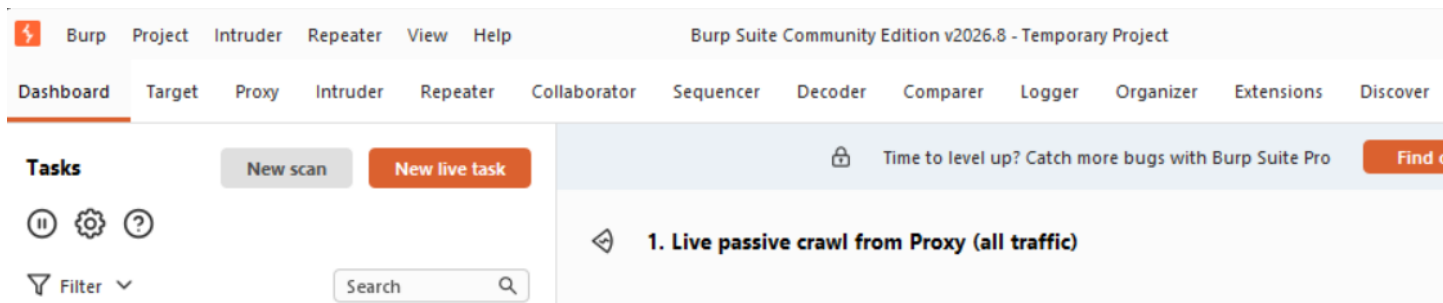


Imagen 5. El las pesañas que están arriba, daremos click en “Proxy”

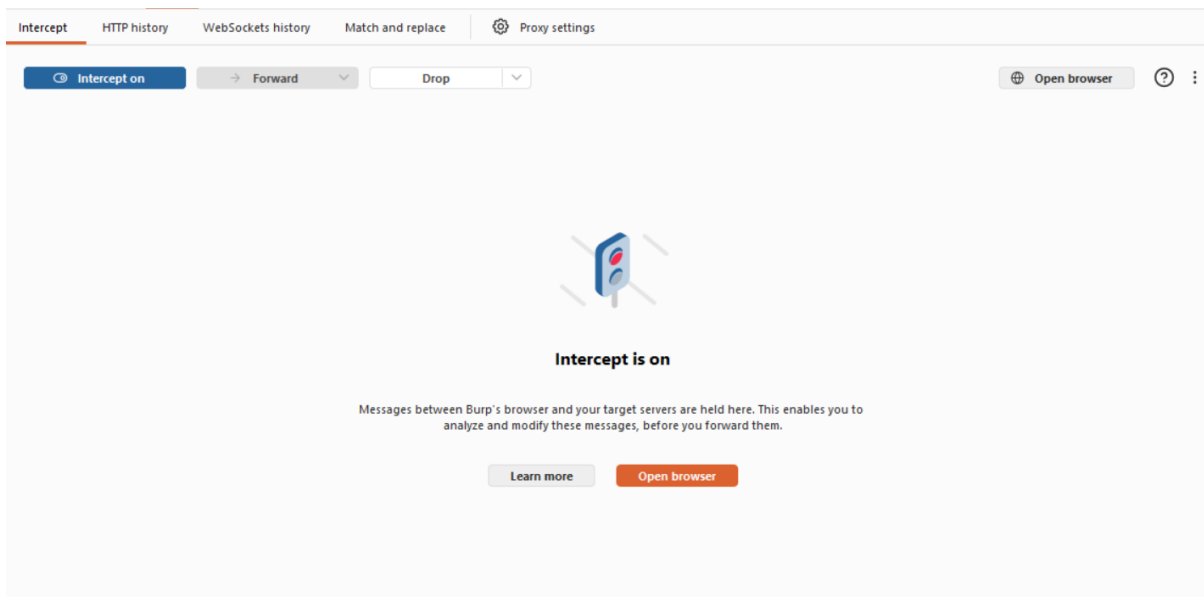


Imagen 6. Daremos click en “Intercept on” para que cambie a “Intercept off” después daremos click en open browser.

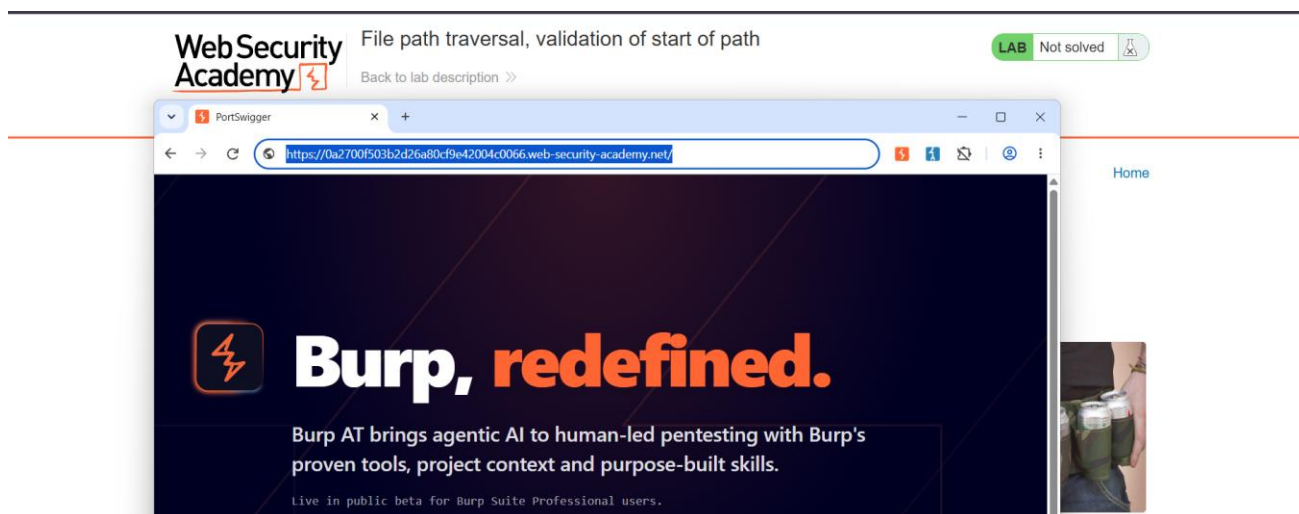


Imagen 7. Se abrirá una pestaña del navegador donde pegaremos la URL que nos dieron cuando accedimos al laboratorio (imagen 2)

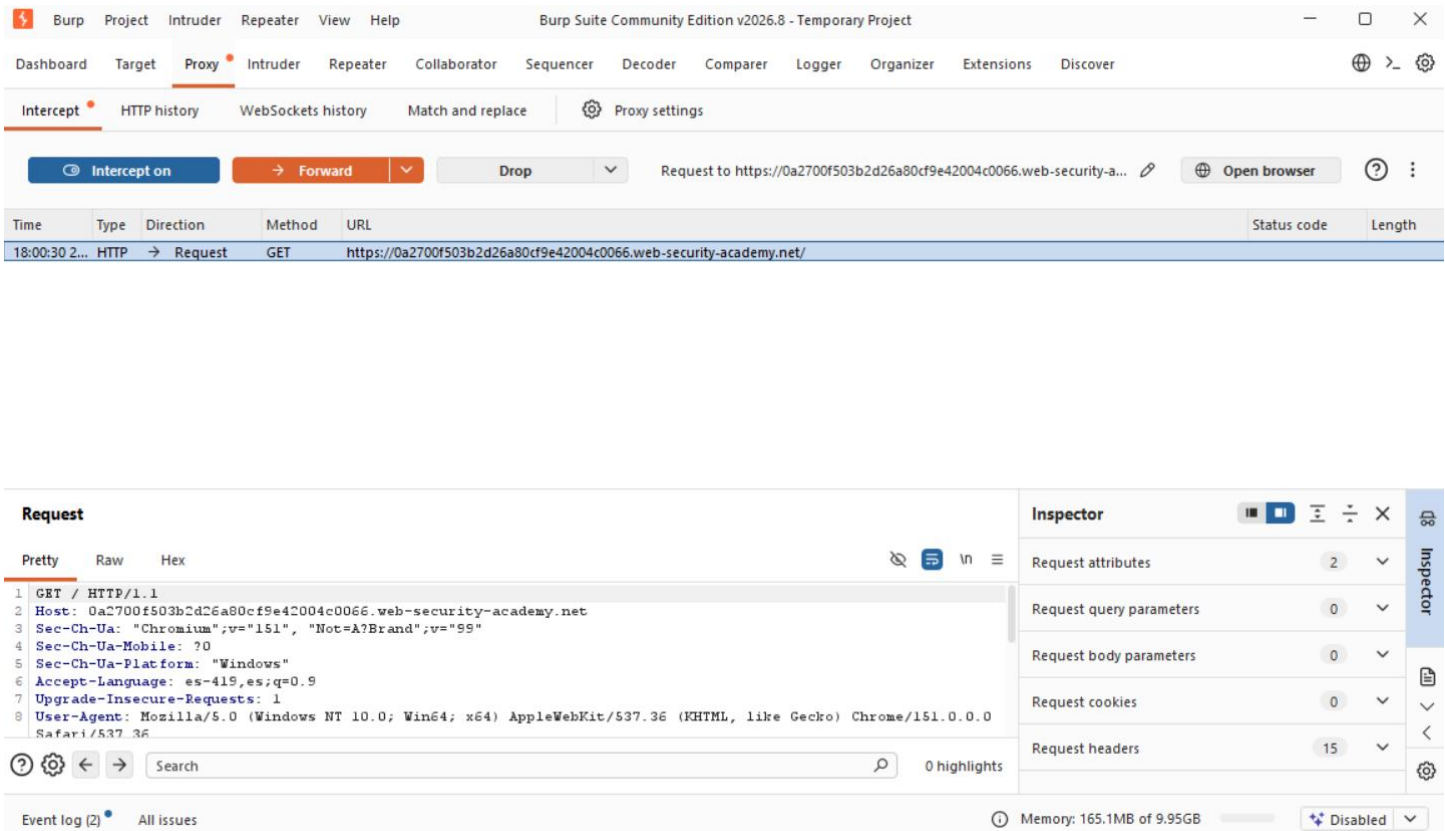


Imagen 8. En BurpSuite nos aparecerá un archivo HTTP, donde presionaremos “FOWARD”

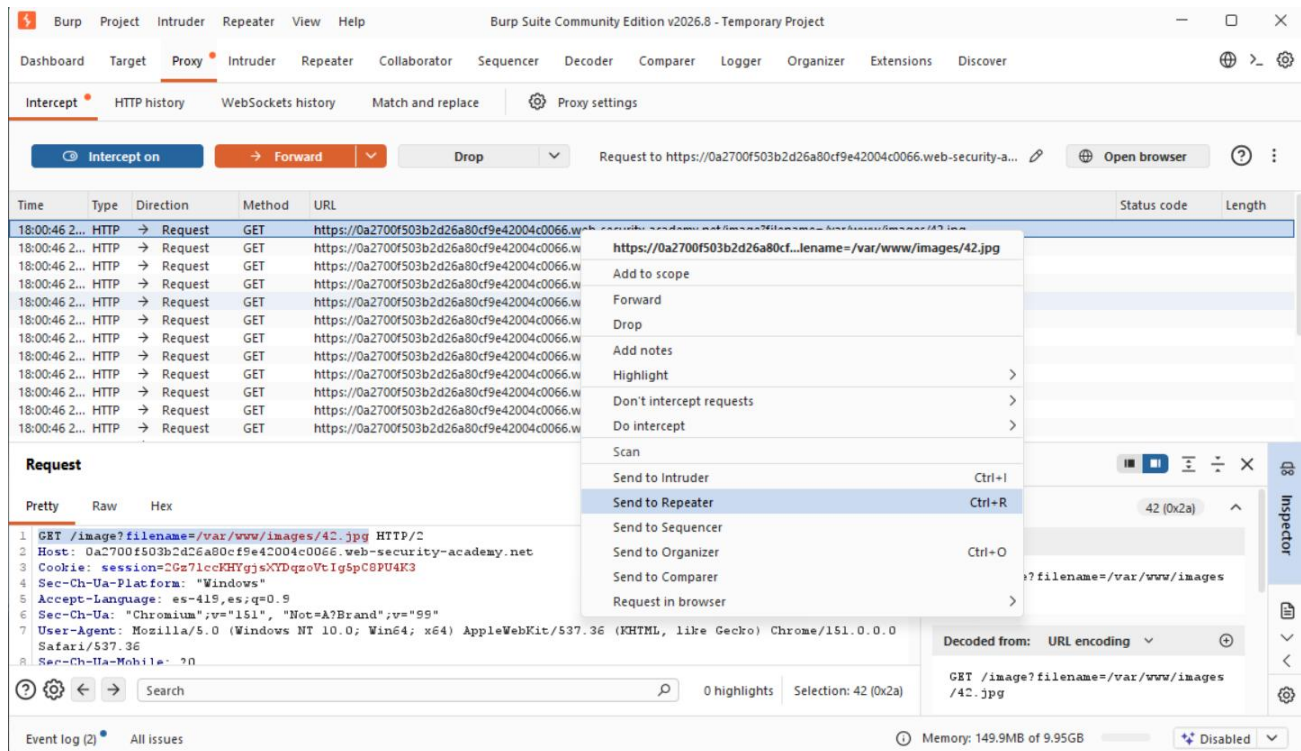


Imagen 9. Se abrirán mas archivos, el que ocuparemos será el que dice “GET /image?filename=var/www/images/42.jpg HTTP/2”. El cual seleccionaremos daremos click y pondremos la opción “Send to Repeater”

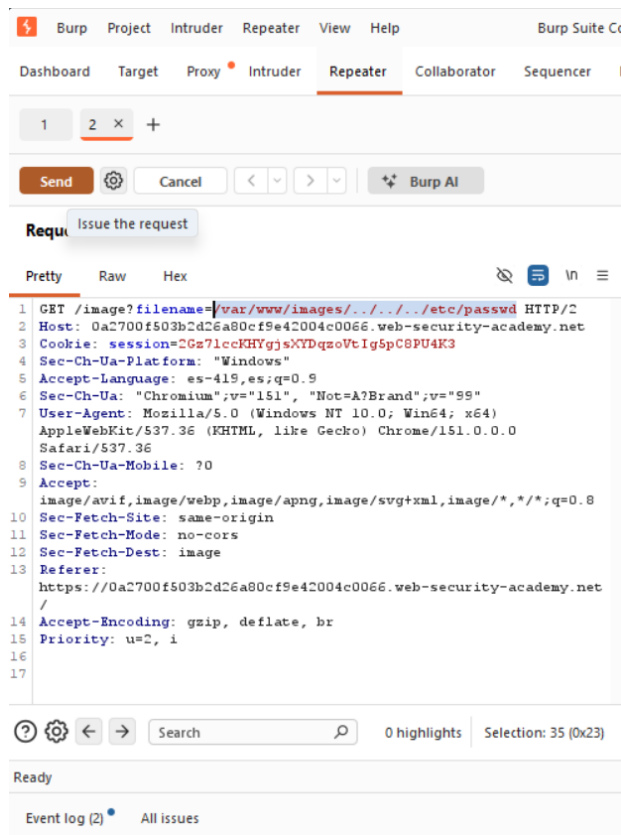


Imagen 11. Nos iremos a la pestaña que se encuentra en la parte superior “Repeater” y la parte que cambiaremos será la seleccionada, en la parte donde estaba “42.jpg” pondremos `../../../../etc/passwd` y daremos click en Send que está en la parte de arriba.

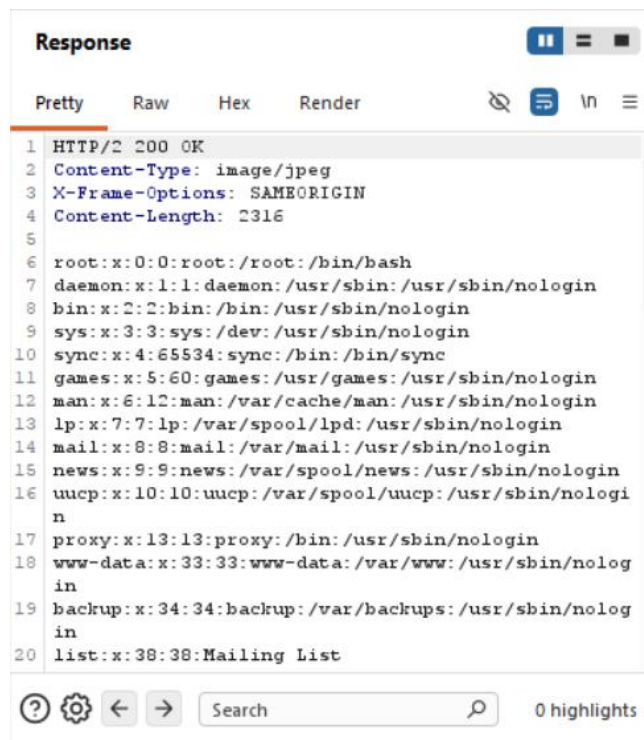


Imagen 13. En el apartado donde dice “Response” aparece el contenido del directorio

Lab: File path traversal, validation of start of path

PRACTITIONER



LAB



Solved



This lab contains a path traversal vulnerability in the display of product images.

The application transmits the full file path via a request parameter, and validates that the supplied path starts with the expected folder.

To solve the lab, retrieve the contents of the `/etc/passwd` file.



ACCESS THE LAB



Solution



Community solutions



Imagen 14. En la página del laboratorio aparecerá que ya está resuelto ese laboratorio (Solved $\sqrt{}$)

5. Mitigación recomendada

Para mitigar esta vulnerabilidad, se recomienda no pasar directamente el *input* del usuario a las APIs del sistema de archivos. Si es estrictamente necesario, se deben aplicar dos capas de defensa:

1. Validar la entrada del usuario utilizando una "lista blanca" (whitelist) de valores permitidos, asegurando que el parámetro solo contenga caracteres alfanuméricos y extensiones de imagen válidas, rechazando cualquier intento que contenga caracteres especiales como `../`.
2. Utilizar funciones del sistema operativo (como `realpath()` en PHP o Java) para resolver la ruta absoluta del archivo solicitado y verificar que la ruta final resuelta comience estrictamente con el directorio base autorizado antes de leer el archivo.